Организационное обеспечение защиты информации

Соколов В.Е.

Информация **—** это *осознанные сведения* об окружающем мире, которые являются объектом хранения, преобразования, передачи и использования.

Сведения — это *знания*, выраженные в сигналах, сообщениях, известиях, уведомлениях и т. д.

Основные виды информации по ее форме представления это:

графическая или изобразительная — первый вид, для которого был реализован способ хранения информации об окружающем мире в виде наскальных рисунков, а позднее в виде картин, фотографий, схем, чертежей на бумаге, холсте, мраморе и др. материалах, изображающих картины реального мира;

звуковая — мир вокруг нас полон звуков и задача их хранения и тиражирования была решена с изобретение звукозаписывающих устройств в 1877 г. ее разновидностью является музыкальная информация — для этого вида был изобретен способ кодирования с использованием специальных символов, что делает возможным хранение ее аналогично графической информации;

текстовая — способ кодирования речи человека специальными символами — буквами, причем разные народы имеют разные языки и используют различные наборы букв для отображения речи; особенно большое значение этот способ приобрел после изобретения бумаги и книгопечатания;

числовая — количественная мера объектов и их свойств в окружающем мире; особенно большое значение приобрела с развитием торговли, экономики и денежного обмена; аналогично текстовой информации для ее отображения используется метод кодирования специальными символами — цифрами, причем системы кодирования (счисления) могут быть разными;

видеоинформация — способ сохранения визуальных картин окружающего мира, появившийся с изобретением кино.

Само понятие И. обычно предполагает наличие по крайней мере *трех объектов*: источника И., потребителя И. и передающей среды. И. не может быть передана, принята или хранима в чистом виде. Носителем ее является сообщение.

Сообщение — это кодированный эквивалент события, зафиксированный источником И. и выраженный с помощью последовательности условных физических символов (алфавита), образующих некую упорядоченную совокупность. Средствами передачи сообщений являются каналы связи. По каналу связи сообщения могут передаваться лишь в единственно приемлемой для этого канала форме сигнала.

Сигнал — это знак, физический процесс или явление, распространяющееся в канале связи и несущее сообщение о каком-либо событии, состоянии объекта наблюдения или контроля, команды управления, указания и т.п. Так, электрические сигналы распространяются в электронных и электрических цепях, акустические — в среде газа, жидкости или твердого тела и т.д.

Несущий И. сигнал, передаваемый средой (каналом) и получаемый потребителем, имеет для последнего определенный ***смысл***, отличный от самого факта поступления этой И. (сообщения). Это достигается за счет специальных соглашений, заключаемых между источником и потребителем И., в соответствии с которыми сигнал интерпретируется, т.е., из получаемого сигнала извлекается понятный потребителю смысл.

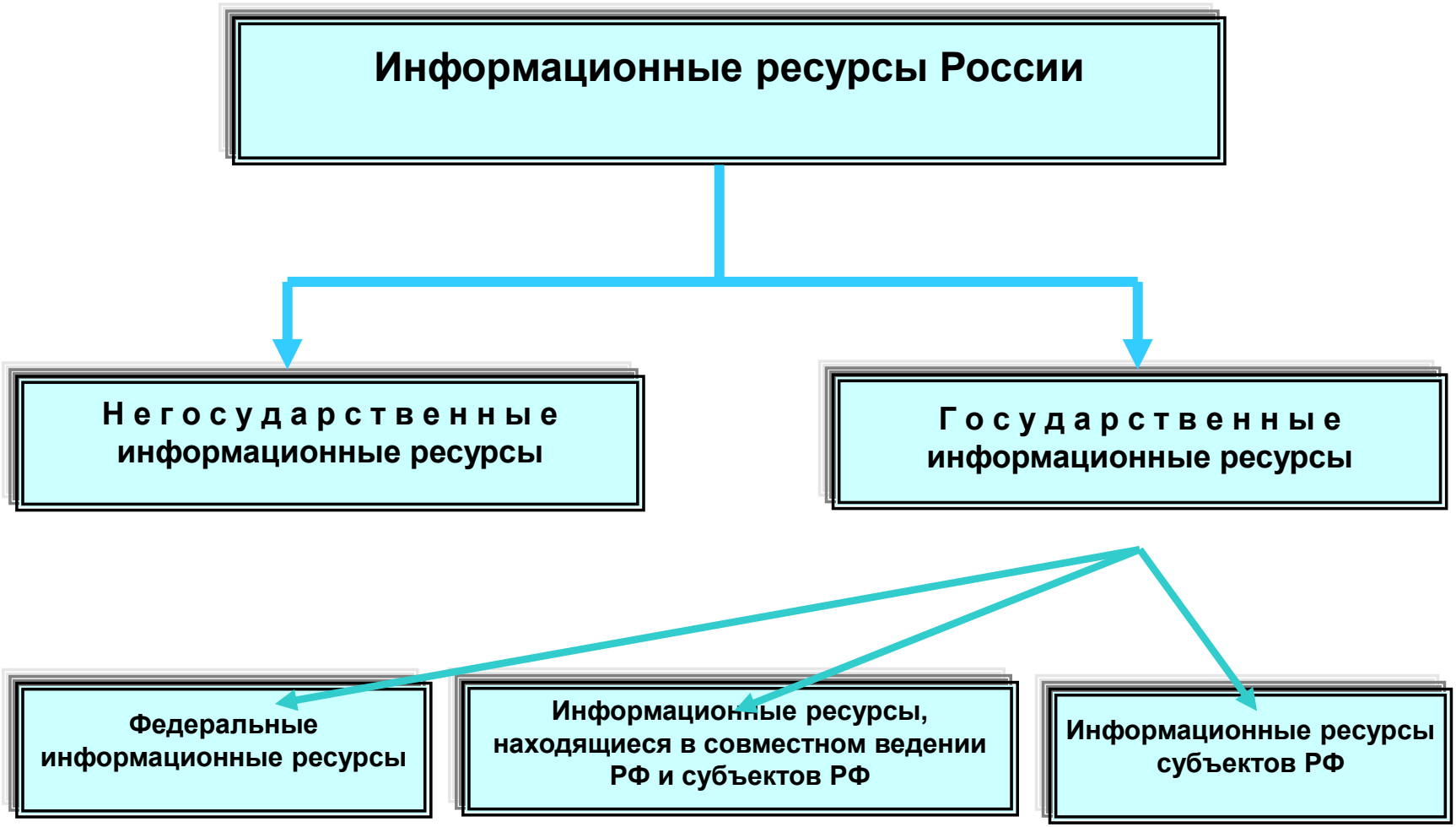
Т.е. простая физическая регистрация принятого сигнала еще не означает, что получена И. от источника, если с помощью известных потребителю правил из этого сигнала не будет извлечен смысл. При этом важно подчеркнуть, что сам сигнал может и не иметь непосредственной физической связи с событием или явлением, о котором он несет И.

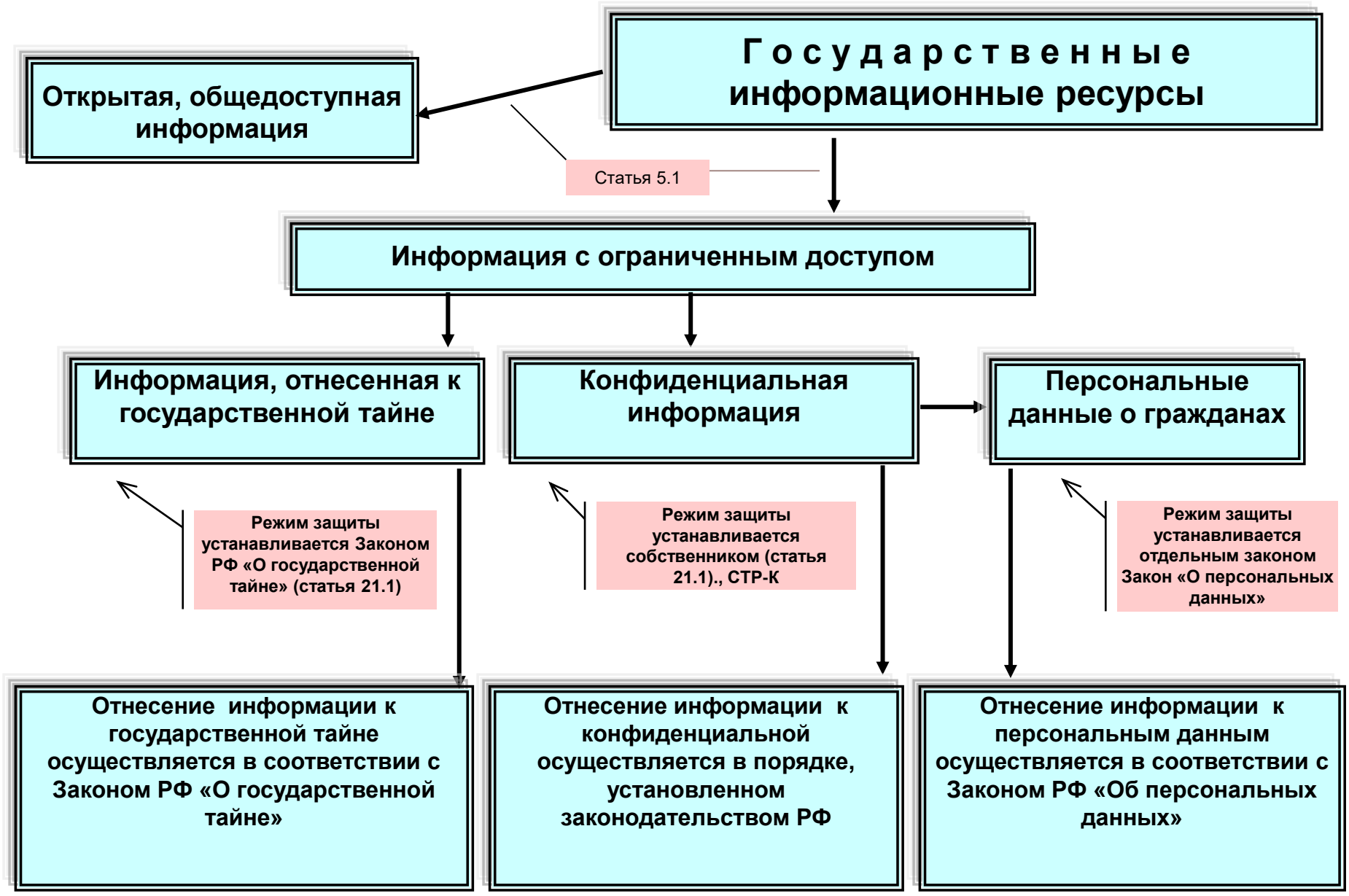
В этом смысле И. выступает как свойство объектов и явлений порождать многообразие состояний, которые посредством отражения передаются от одного объекта к другому и запечатлеваются в его структуре.

Организация защиты информации

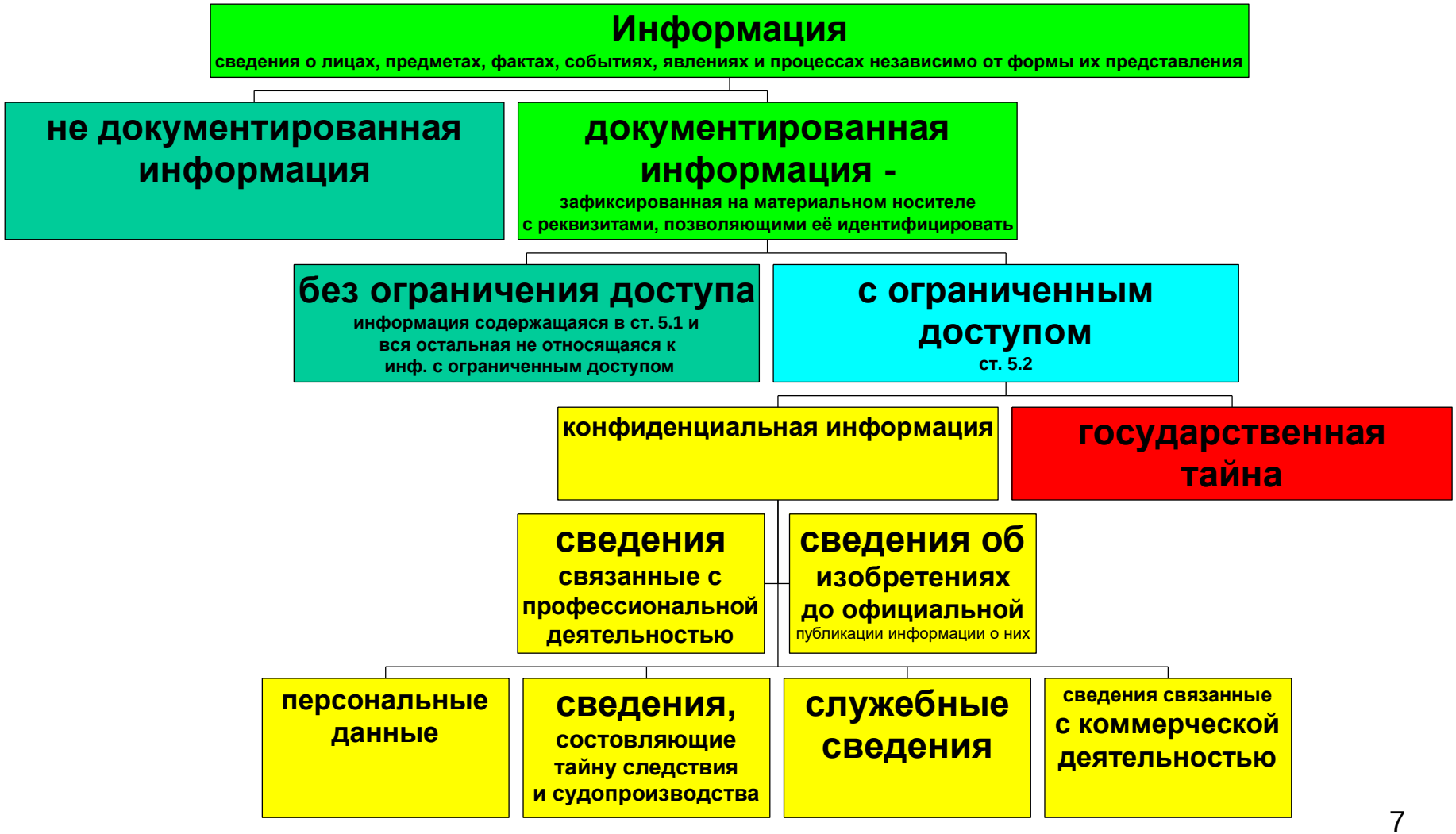
- В терминах информационной безопасности, Информация обладает следующими основными свойствами:
  - **Конфиденциальность** – способность информации обеспечивать защиту от несанкционированного доступа к ее содержанию (примером нарушений конфиденциальности могут служить те случаи, когда с информацией ознакомляются субъекты, не имеющие прав доступа к ней).
  - **Целостность** – способность информации обеспечивать защиту от несанкционированного ее уничтожения и модификации. Под целостностью подразумевается актуальность и непротиворечивость информации, ее защищенность от разрушения и несанкционированного изменения (примеры нарушения целостности – утеря, выход из строя носителя; нарушение смысловой значимости; нарушение логической связанности; потеря достоверности, имеющая место в тех случаях, когда содержимое информации не соответствует текущему состоянию реальности).
  - **Доступность** – это возможность за приемлемое время получить требуемую информационную услугу. Если по тем или иным причинам предоставить эти услуги пользователям становится невозможно, это, очевидно, наносит ущерб всем субъектам информационных отношений (например, когда пользователь не может получить доступ к информации; при этом, несмотря на отсутствие доступа, сама информация не теряется).

Организация защиты информации




Государственные информационные ресурсы
Открытая, общедоступная информация
Статья 5.1
Информация с ограниченным доступом
Информация, отнесенная к государственной тайне
Конфиденциальная информация
Персональные данные о гражданах
Режим защиты устанавливается Законом РФ «О государственной тайне» (статья 21.1)
Режим защиты устанавливается собственником (статья 21.1)., СТР-К
Режим защиты устанавливается отдельным законом Закон «О персональных данных»
Отнесение информации к государственной тайне осуществляется в соответствии с Законом РФ «О государственной тайне»
Отнесение информации к конфиденциальной осуществляется в порядке, установленном законодательством РФ
Отнесение информации к персональным данным осуществляется в соответствии с Законом РФ «Об персональных данных»

Организация защиты информации



Организация защиты информации

Требования и рекомендации распространяются на защиту:

- Конфиденциальной информации - информации с ограниченным доступом, в соответствии с "Перечнем сведений конфиденциального характера", утвержденного Указом Президента Российской Федерации от 06.03.97 №188

- Информации о фактах, событиях и обстоятельствах частной жизни гражданина, позволяющей идентифицировать его личность (персональные данные) *(В соответствии с Федеральным законом "Об информации, информационных технологиях и защите информации"* №149 от 27 июля 2006 г. и *Федеральным законом "О персональных данных« №152 27 июля 2006 года*)

Организация защиты информации

Защите подлежит:

- речевая информация;
- информация обрабатываемая техническими средствами, а также представленная в виде информативных электрических сигналов, физических полей, носителей на бумажной, магнитной, оптической и иной основе, в виде информационных массивов и баз данных в АС.

Защищаемыми объектами информатизации являются:

- средства и системы информатизации, используемые для обработки конфиденциальной информации;
- технические средства и системы, не обрабатывающие непосредственно конфиденциальную информацию, но размещенные в помещениях, где она обрабатывается (циркулирует);
- защищаемые помещения.

Под угрозами понимают потенциальную или существующую опасность совершения какого-либо деяния (действия или бездействия), направленного против объекта защиты, наносящего ущерб собственнику (владельцу, пользователю) информационных ресурсов

УГРОЗЫ РАЗЛИЧАЮТ:

1. Случайные:

- **ошибки и сбои в работе программных и технических средств АС;**
- **стихийные бедствия;**
- **ошибки в работе пользователей и т. п.**

2. Преднамеренные

со стороны нарушителей (злоумышленников), которые сознательно стремятся получить несанкционированный доступ к ресурсам АС или нарушить ее работоспособность.

РАЗНОВИДНОСТИ УГРОЗ

1. Конфиденциальности информации:

- **хищение (копирование) информации и средств её обработки;**
- **утрата (неумышленная потеря, утечка) информации.**

2. Целостности информации:

- **модификация (искажение) информации;**
- **отрицание подлинности информации;**
- **навязывание ложной информации.**

3. Доступности информации:

- **блокирование информации;**
- **уничтожение информации и средств её обработки.**

Организация защиты информации

Любая угроза действует через уязвимость.

Угрозы без уязвимости не бывает!!!

Не стоит путать *уязвимость* и *закладку*

Организация защиты информации

- **Уязвимость** – свойство информационной системы, обусловливающее *возможность* реализации угрозы безопасности обрабатываемой в ней информации (ГОСТ Р 50922-2006 "Защита информации. Основные термины и определения")

- **Уязвимость** - это недостаток (слабость) программного (программно-технического) средства или информационной системы в целом, который *может быть* использован для реализации угроз безопасности информации. (В ГОСТ Р 56545-2015 "Защита информации. Уязвимости информационных систем. Правила описания уязвимостей")

Организация защиты информации

- **Программная закладка** - это *преднамеренно* внесенный в программное обеспечение функциональный объект, который при определенных условиях инициирует реализацию недекларированных возможностей программного обеспечения. (ГОСТ Р 51275-2006 "Защита информации. Объект информатизации. Факторы, воздействующие на информацию. Общие положения".)

- **Программная закладка** – *преднамеренно* внесенные в ПО функциональные объекты (то есть элементы программы, осуществляющие выполнение действий по реализации законченного фрагмента алгоритма программы), которые при определенных условиях (входных данных) инициируют выполнение не описанных в документации функций ПО, приводящих к нарушению конфиденциальности, доступности или целостности обрабатываемой информации. (ГОСТ Р 50.1.053-2005 "Информационные технологии. Основные термины и определения в области технической защиты информации").

Организация защиты информации

Таким образом, деление проходит по понятию "**умысел**".

- **Есть** намерение навредить - значит речь идет о закладке.
- **Нет** намерения навредить – это уязвимость.
- При этом, уязвимость нельзя считать недекларированной возможностью, так она не является функциональной возможностью ПО согласно приведенным определениям.
- **Недекларированные возможности** – это функциональные возможности ПО, не описанные или не соответствующие описанным в документации, при использовании которых возможно нарушение конфиденциальности, доступности или целостности обрабатываемой информации. Реализацией недекларированных возможностей, в частности, являются программные закладки.

Факторы, способствующие повышению уязвимости АС:

- увеличение объемов информации, накапливаемой, хранимой и обрабатываемой с помощью АС;
- повышение степени автоматизации обработки данных в АС;
- интеграция в базах данных информации больших объемов, различного назначения и принадлежности;
- усложнение режимов функционирования технических средств АС и увеличение сложности программного обеспечения;
- долговременное хранение данных на внешних носителях информации;
- расширение круга пользователей, имеющих доступ к ресурсам АС;
- возрастание важности и ответственности решений, принимаемых на основе автоматизированной обработки данных в АС;
- большая концентрация и широкая территориальная расположенность АС;
- повышение интенсивности циркуляции информации между АС, объединенными в сети различного масштаба.

Угрозы исходят от источников угроз (ИУ), которые могут быть внешними и внутренними.

Источники угроз,

обусловленные:

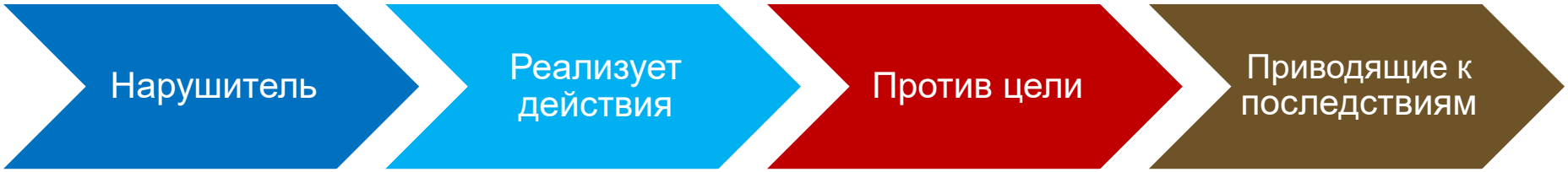
Действиями субъекта (антропогенные ИУ); которые могут быть квалифицированы как умышленные или случайные преступления.

Техническими средствами (техногенные ИУ); определяемые технократической деятельностью человека и развитием цивилизации.

Стихийными источниками: стихийные бедствия или иные обстоятельства, которые невозможно предотвратить при современном уровне человеческих знаний и возможностей.

Организация защиты информации

- Само понятие угроза состоит из нескольких элементов
  - Есть нарушитель
  - Который реализует какие-то действия против цели
  - Которые приводят к происшествиям или последствиям



Организация защиты информации

- Поэтому основная задача специалиста в области защиты информации в том числе состоит в обнаружении этих 4-х элементов

- С помощью обычных решений находится до 95% атак

- Для формирования защиты против этих атак расходуется порядка 50% бюджета на традиционные средства защиты

Организация защиты информации

- Оставшиеся 5% составляют основную проблему для информационной безопасности

- Как правило, мы не всегда знаем
  - что у нас вообще произошла какая-то проблема,
  - мы не знаем откуда она произошла,
  - мы не знаем точку входа
  - мы не знаем как давно эта проблема возникла

- Поэтому основная задача как можно раньше обнаружить проблему

Организация защиты информации

- Мы должны выстраивать защиту исходя из парадигмы не **Почему и зачем нас атаковать**? А **Когда нас атакуют**?
- Т.е. мы должны исходить из того что нас в любом случае атакуют.
- А мы должны это вовремя обнаружить и среагировать. Для этого нужны технологии обнаружения атак.

